

TEMPLATE REPORTE EJECUTIVO — POWERPOINT STRUCTURE

Presentación Junta Directiva (10-12 slides)

Versión: 2.0 | **Fecha:** Enero 2026 | **Nota:** Descarga .pptx desde link

SLIDE 1: PORTADA

Contenido

EVALUACIÓN INTEGRAL CIBERSEGURIDAD
Cyber Risk Management 2024-2025

Índice Global Madurez (IGM): 2.38
Nivel: FORMATIVO

[Logo Organización]

Fecha: Enero 2026
Clasificación: Confidencial - Junta

SLIDE 2: EXECUTIVE SUMMARY (1 PÁGINA)

Contenido

SITUACIÓN ACTUAL

✓ Fortalezas:

- Vulnerabilidades management (3.2/4.0) – Scanning continuo
- Gobernanza (3.5/4.0) – RAS documentado; CIS0 designado
- Compliance GDPR (85%) – Mayormente conforme

x Debilidades Críticas:

- Cuantificación FAIR (2.0/4.0) – ROI decisions ad-hoc
- Automatización (1.8/4.0) – Manual heavy; scaling problem
- Supply Chain Risk (1.5/4.0) – Terceros no auditados

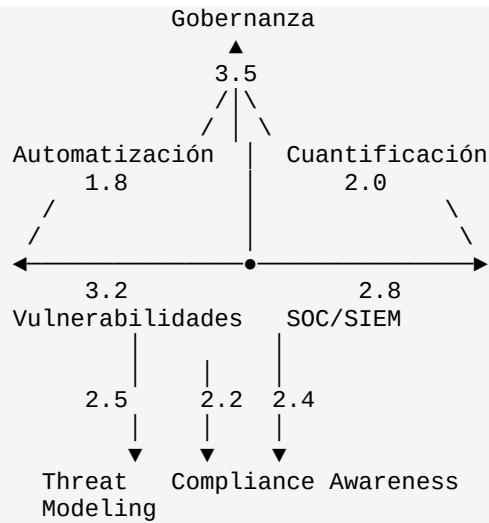
GAPS MÁS CRÍTICOS:

1. Cuantificación monetaria riesgos (-2.0)
2. Supply chain governance (-2.0)
3. Automatización + Policy-as-Code (-1.4)

 **INVERSIÓN RECOMENDADA 12 meses: €500K**
 **ROI Esperado: 580% (€3.4M avoided losses)**

SLIDE 3: IGM RADAR CHART

Visualización



IGM = 2.38 (Formativo)
Target 2027 = 3.8 (Estratégico)

SLIDE 4: BENCHMARK vs PEERS

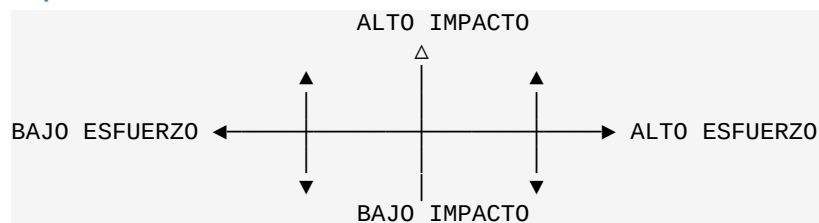
Gráfico Comparativo

	España Median	Vuestra Org	EU Leader
IGM	2.40	2.38	3.86
Gobernanza	2.8	3.5	4.2
Cuantificación	1.8	2.0	3.8
Threat Model	2.2	2.5	3.5
SOC/SIEM	2.6	3.0	4.0
Vulnerabilidades	3.0	3.2	4.1
Supply Chain	1.9	1.5	3.6
Awareness	2.4	2.8	3.8
Compliance	2.3	2.2	4.0
Automatización	1.5	1.8	3.7

CONCLUSIÓN: Sobre median España; bajo vs líderes UE
BRECHA: -1.48 nivel (4-5 años para alcanzar Level 4 Estratégico)

SLIDE 5: GAPS PRIORIZACIÓN MATRIX

Impacto × Esfuerzo



CUADRANTE 1: QUICK WINS

- ✓ FAIR Implementation
- ✓ Awareness Training ROI
- ✓ CVSS v4.0 Migration

Esfuerzo: 4-8 semanas | Budget: €100K | ROI: 400-500%

CUADRANTE 2: STRATEGIC PROGRAMS

- ⚠ Supply Chain Audit Program
- ⚠ SIEM + SOAR Deployment
- ⚠ Policy-as-Code Implementation

Esfuerzo: 12-16 semanas | Budget: €350K | ROI: 300-600%

CUADRANTE 3: AVOID (No hacer)

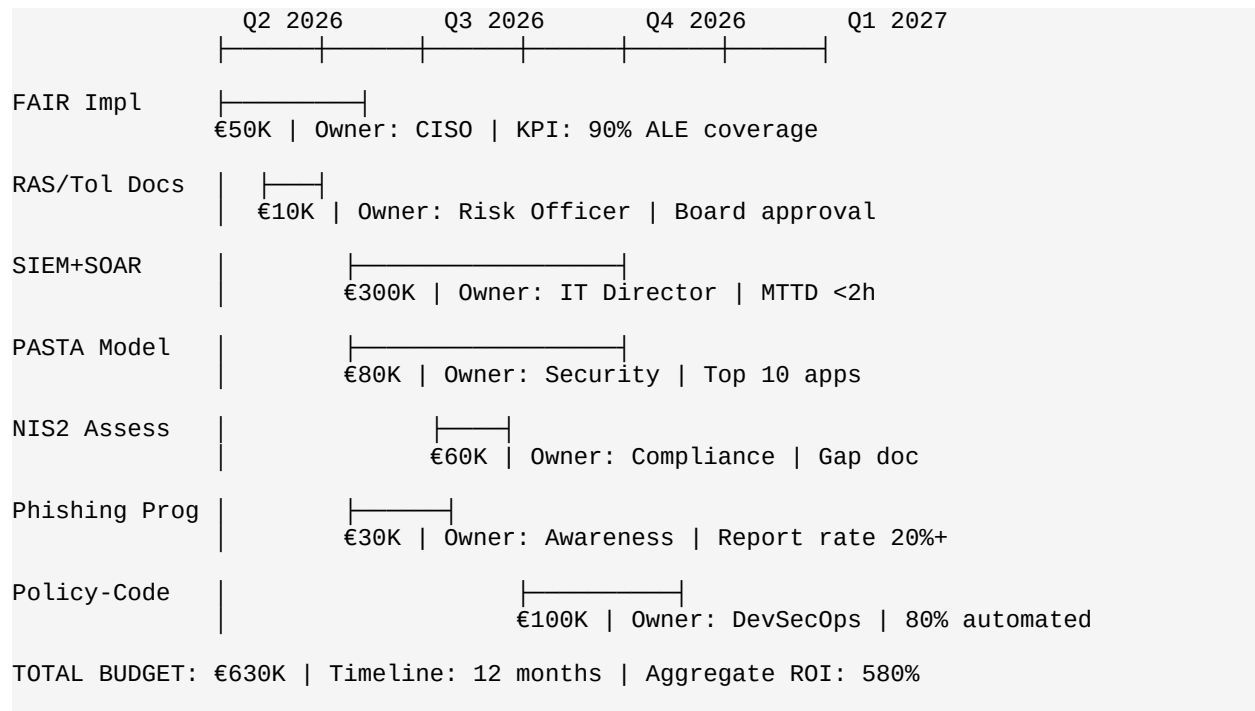
- ✗ Legacy system upgrades (bajo impacto)
- ✗ Redundant tool purchases

CUADRANTE 4: NICE-TO-HAVE

- 📋 Advanced ML threat detection
- 📋 Quantum-safe crypto migration (future 2027+)

SLIDE 6: ROADMAP 12-24 MESES

Timeline Visual



SLIDE 7: COMPLIANCE REGULATORY GAP

Status por Regulación

GDPR (vigente mayo 2018)

- Status: ✓ 85% Compliant
- Gap: Art 32 (security measures), Art 33 (breach notify)
- Risk: Medium
- Timeline: Q2 2026 → 95%+

DORA (vigente enero 2025 – SECTOR FINANCIERO ONLY)

- Aplicable: [SI/NO] → Si financiero: CRÍTICO
- Status: ⚠️ 70% Compliant
- Gap: RTO/RPO <4h no validado; third-party audit incomplete
- Risk: VERY HIGH (sanciones €10M si financiero)
- Timeline: Q1 2026 → 100% obligatorio

NIS2 (españa Q1 2026 transposición – TODOS SECTORES)

- Aplicable: [Sector crítico?] → Si sí: CRÍTICO
- Status: ⚠️ 60% Preparado (anticipatory compliance)
- Gap: Incidente 24h reporting; supply chain audit
- Risk: VERY HIGH (sanciones €10M essential, €7M important)
- Timeline: Q1-Q2 2026 → Priority #1

SLIDE 8: FINANCIAL IMPACT & ROI

ALE Current vs Post-Implementation

CURRENT STATE (Baseline 2024)

Annual Loss Expectancy (ALE): €8.2M

Top Risks:

1. Ransomware: €3.5M
2. Data Breach: €2.2M
3. Business Disruption: €1.2M
4. Phishing/Social Eng: €0.9M
5. Supply Chain: €0.4M

POST-IMPLEMENTATION (2027)

Annual Loss Expectancy: €4.8M
ALE Reduction: €3.4M

Risk Mitigation:

Ransomware (SIEM): -60% → €1.4M
Data Breach (FAIR): -45% → €1.2M
Disruption (RTO<4h): -65% → €0.4M
Phishing (Train): -70% → €0.27M
Supply Chain (Audit): -80% → €0.08M

INVERSIÓN: €630K

AHORRO ANUAL: €3.4M

ROI: 540% | PAYBACK: 2.2 meses | 5-AÑO NPV: €15.7M

SLIDE 9: GOVERNANCE DECISIONS REQUIRED

Acciones Junta

DECISIÓN 1: Aprobación Roadmap

- Presupuesto: €630K (aprobación formal)
- Timeline: 12 meses
- Owner: CFO (presupuesto); CISO (ejecución)
- Status: [] Aprobado [] Condicionado [] Rechazado

DECISIÓN 2: Risk Appetite Statement

- Documento: Formal RAS + Risk Tolerance umbrales
- Approval: Junta firmando
- Revisión: Anual mandatorio
- Owner: Risk Officer

DECISIÓN 3: CISO Accountability

- Reporte directo CEO/Presidente
- Compensation: TBD (ej: 20% tied to IGM improvement)
- Authority: Presupuesto + hiring authority
- Status: [Formalizar]

DECISIÓN 4: Terceros Governance

- Auditoría anual proveedores críticos
- Contractual security mandates
- SBOM requirement para new contracts
- Owner: Procurement + CISO

SLIDE 10: RISKS & MITIGATIONS

Riesgos Implementación

RIESGO 1: Project Slippage

- Probabilidad: Medium (40%)
- Impacto: €50-100K costo extra
- Mitigación: Project management office (PMO); weekly tracking
- Owner: CISO

RIESGO 2: Talent Shortage

- Probabilidad: High (60%) – FAIR consultants caros
- Impacto: Presupuesto +20%
- Mitigación: Hiring 1-2 junior analistas; training propios
- Owner: HR + CISO

RIESGO 3: Technology Integration

- Probabilidad: Medium (35%) – SIEM + legacy systems
- Impacto: MTTD delays
- Mitigación: POC phase (4 semanas) antes full deployment
- Owner: IT Director

RIESGO 4: Regulatory Change

- Probabilidad: Medium (50%) – NIS2 aún en transposición
- Impacto: Requisitos adicionales
- Mitigación: Flexibility en roadmap (30% buffer)
- Owner: Compliance Officer

SLIDE 11: NEXT STEPS & TIMELINE INMEDIATO

Acciones 30-90 Días

PRÓXIMOS 30 DÍAS (Febrero 2026)

- ✓ Junta aprueba roadmap + presupuesto
- ✓ Designar project leads por cada iniciativa
- ✓ Publicar RFP para FAIR consulting
- ✓ Iniciar vendor selection SIEM/SOAR

PRÓXIMOS 60 DÍAS (Marzo 2026)

- ✓ Contratar consultores FAIR
- ✓ Kick-off FAIR assessment (2 semanas)
- ✓ Publicar RFP SIEM/SOAR
- ✓ Vendor selection SIEM

PRÓXIMOS 90 DÍAS (Abril 2026)

- ✓ FAIR assessment completo + ALE models
- ✓ First FAIR-based control decisions
- ✓ SIEM POC comenzar
- ✓ Training SIEM team comenzar
- ✓ Policy-as-Code team formar

SLIDE 12: CLOSING & Q&A

Contenido

RESUMEN EJECUTIVO (3-liner)

1. Madurez CRM actual: 2.38/4.0 (Formativo)
2. Gaps críticos: Cuantificación, Supply Chain, OT
3. Inversión + ROI: €630K → €3.4M/año (540% ROI)

RECOMENDACIÓN

Aprobar roadmap 12-24 meses; comenzar Q2 2026 con QUICK WINS (FAIR, Awareness) para demostrar valor antes STRATEGIC programs (SIEM, Policy-Code)

PREGUNTAS & DISCUSIÓN

DESCARGAR POWERPOINT

Archivo: **CRM_Reporte_Ejecutivo.pptx** (link en README)

- Slides 1-12 con templates pre-formados
- Gráficos interactivos (radar, timeline, benchmarks)
- Colores brand-aligned (personalizable)
- Notas speaker por slide

Fin Template PowerPoint